

Capstone Project: Threat & Risk Assessment (TRA)

Course: Cyber Blue

Student Name: Raju Deb

Lab Environment: AWS

Submission Date: 19-03-2026

1. Executive Summary

This threat and risk assessment describes a simulated security incident in a regulated AWS cloud environment. The analysis found that the organization's cloud access controls were far too weak around identity and privilege management. It had too many users, roles, and policies, but important security controls, such as multi-factor authentication for privileged users and permission boundaries, weren't in place in the environment. Collectively, the weaknesses made it more likely that a cloud identity would be abused to gain wider access around the environment.

The incident report demonstrates that a cloud role linked to the organization's operational environment was exploited for malicious purposes and subsequently accessed sensitive financial reporting data stored in Amazon S3. This demonstrates that the problem involved the threat not just of a small security flaw, but of a genuine threat of unauthorized access to critical business information. In a regulated enterprise setting, this type of exposure can result in regulatory risks, financial risk, reputation damage, and loss of business as usual. Based on the available evidence, the risks for this incident are high overall. The two biggest risks exposed in this assessment are: **(1) excessive IAM privileges enabling privilege escalation opportunity and broader AWS account compromise**, and **(2) unauthorized access to sensitive financial reporting data stored in S3**.

To mitigate these risks, the organization should better define cloud identity controls, restrict unnecessary access rights, provide better protection of privileged accounts, enhance controls for sensitive data, and improve detection of and response to anomalous cloud behavior.

2. System Overview

Cloud Platform: Amazon Web Services (AWS)

Environment Role: Regulated production cloud environment supporting CI/CD, internal services, and sensitive financial reporting workloads

Exposure Context: Cloud identity and access management risk involving IAM roles, policies, S3 access, CloudTrail, and SIEM monitoring

Assumptions: Assessment is based on the Appendix A evidence provided in the capstone materials

Description: This report reviews a controlled AWS production environment in which cloud identity and access management (IAM) is central to business operations. CI/CD pipelines, internal application services, and sensitive financial reporting data stored in Amazon S3 are among the critical services supported by the environment. Because access in these workloads is regulated by IAM roles, vulnerabilities like excessive permissions, missing MFA, and a lack of permission boundaries can directly lead to identity misuse to unauthorized access over critical cloud resources and business-sensitive data.

3. Assets at Risk

Asset 1: AWS IAM Identities, Roles, and Policies.

Importance: The reasons why IAM identities, roles, and policies are valuable are that they give users control to access different types of cloud resources in the AWS environment. IAM is especially critical for this endeavour as it supports CI/CD operations, internal services, and administrative functions. In this area, weaknesses could allow an attacker to enumerate identities, identify privileged access paths, and misuse some permissions in the process for broader compromise. **Appendix A — Figure 1;** Principal: AWS IAM environment; Risk: Excessive Privilege & Identity Sprawl. **Appendix A — Figure 2;** API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role.

Asset 2: CI/CD-Build-Role.

Importance: The CI/CD-Build-Role is valuable, as it is a high-impact operational identity that operates within the cloud environment and is directly correlated to the suspicious activity seen in the incident. The appendix evidence indicates that this role was attached to the DevOps-ExtendedAccess policy and that it later showed up in the SIEM alert and in the CloudTrail S3 access event. Misuse of this identity leads to a significant security risk, as the role may interact with IAM and sensitive production resources. **Appendix A — Figure 2;** API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CI/CD-Build-Role. **Appendix A — Figure 3;** EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CI/CD-Build-Role. **Appendix A — Figure 4;** EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CI/CD-Build-Role.

Asset 3: Sensitive Financial Reporting Data in Amazon S3.

Importance: Amazon S3 retains valuable financial reporting data, which represents sensitive production business information in a regulated environment. Any unauthorized access to this data presents confidentiality issues, risk of compliance violation, financial loss, damage to reputation, and potential business interruption. The prod-finance-reports bucket was successfully accessed when the incident occurred to make this one of the most valuable assets in the assessment (as documented in the appendix). **Appendix A — Figure 4;** EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CI/CD-Build-Role

4. [Methodology](#)

This Threat & Risk Assessment was accomplished through an evidence-based analytical methodology, centered on the canonical artifacts identified in Appendix A (the IAM Dashboard Overview, IAM Policy Review, SIEM alert for IAM enumeration, CloudTrail event for S3 object access, and raw JSON snippets to support the review). These items were considered the ultimate truth for reconstructing the timeline of the incident, the misconfigurations in IAM, evaluating privilege escalation opportunities, and the business relevance of the observed action.

Evidence Reviewed: The assessment was based on the following Appendix A artifacts:

- Figure 1 — IAM Dashboard Overview
- Figure 2 — IAM Policy Review
- Figure 3 — SIEM Alert — IAM Enumeration
- Figure 4 — CloudTrail — S3 Object Access
- Supporting JSON snippets for IAM policy, CloudTrail event, and SIEM alert

Analytical Approach: The analysis was then completed systematically. First, each artifact was checked and analyzed for technical indicators, including but not limited to: IAM users, roles, policies, privileged access conditions, high-risk permissions, alert severity, timestamps, principal identity, API calls, and affected S3 resources. Second, they mapped the findings across artifacts, creating a chronological incident story. Third, the observed activity was aligned to relevant MITRE ATT&CK tactics and techniques. Finally, the two highest-impact risks were evaluated via likelihood, impact, and business consequence.

SIEM and CloudTrail: SIEM and CloudTrail correlation was the main feature of the approach. The SIEM alert was leveraged to trace back to the origin of the suspicious activity, which included the initial calling, its severity, and discovery-related API actions. The subsequent GetObject activity was validated against the prod-finance-reports bucket with CloudTrail. Correlation was done as follows:

- principal ARN
- event time

- API activity

This approach supported the discovery that the same role first performed IAM discovery and later accessed sensitive S3 data. **Appendix A — Figure 3**; EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CI/CD-Build-Role. **Appendix A — Figure 4**; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CI/CD-Build-Role.

IAM Policy Review: By translating permissions into an attacker capability, an IAM policy analysis was carried out. Particular attention has been given to permissions for escalation risk, such as iam:PassRole, iam:AttachRolePolicy, and iam:PutRolePolicy along with broad authorization parameters like Resource: "*", no condition block, no MFA enforcing and no permission boundaries. The review thus enabled to identify if the CI/CD-Build-Role had escalation-related permissions that might allow for more sweeping privilege abuse in the AWS environment. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CI/CD-Build-Role.

The MITRE ATT&CK mapping: This approach was used to classify the observed behavior by using the correct tactic categories, technique IDs, and technique names. Mapping discovery activity using ListUsers, GetPolicy, and ListRoles was given by T1087.004, Account Discovery: Cloud Account, under the Discovery tactic was done. The escalation-capable IAM policy was verified against T1098 — Account Manipulation and T1548.005 — Abuse Elevation Control Mechanism: Temporary Elevated Cloud Access. Successful GetObject activity against S3 was mapped to T1530 — Data from Cloud Storage, and the use of the CI/CD-Build-Role supported T1078.004 — Valid Accounts: Cloud Accounts. Mappings supported by the provided appendix evidence were used only.

Risk Assessment Approach: The approach to risk assessment was qualitative and business focused, informed by the 5×5 likelihood and impact matrix in **Appendix B**, estimated by ease of exploitation, the existence of escalation-capable permissions, the absence of preventive controls, and observed behaviour of actors. Impact was evaluated against the sensitivity of the data impacted, the privilege level of the role involved, the potential blast radius in the AWS environment, and the business effects of a regulated enterprise cloud context. This strategy served as a set of criteria for assigning the prioritisation of the top two material risks identified in the assessment.

5. Threat Actors and Threat Landscape

The most appropriate explanation for a threat in this situation is an unauthorized entity that gained access to a valid AWS cloud identity and did so in an abuse role, and an assigned role linked to the company's CI/CD and operations. The evidence in the appendix indicates that it is more likely cloud identity misuse than traditional malware-based compromise, as

much of its attack relies on AWS permissions and API calls rather than destructive or noisy attack methods. So in this scenario, the actor could be, for example, an outside attacker with access obtained to the system and access to it, or an insider operator abusing an over-permissioned cloud role.

In this case, the most likely motivation is unauthorized access to sensitive enterprise resources, especially those related to privileged control of financial resources and potentially valuable information. These data insights from the IAM discovery behavior indicate that the actor was intrigued with the cloud identity schema, identifying potential permissions, while subsequent successful access to the prod-finance-reports bucket indicates an interest in sensitive business data. Such activity could be driven by data theft, unauthorized intelligence collecting, privilege abuse, or an account compromise to facilitate future persistence or operational impact within a regulated environment like AWS. And for this example, the more nebulous threat landscape seems to be cloud identity abuse. The organization works in a cloud-first DevOps-enabled AWS provider environment in which IAM Roles play a crucial role in driving business operations and automation. In these environments, attackers are more likely to attack identity, roles, and permissions because they can now access a structure via proper cloud infrastructure, but also prevent more obvious perimeter detection. For that reason, over-permissioned or poorly controlled IAM roles are a high-risk attack surface in terms of influence.

A second critical threat within this environment is privilege escalation due to IAM misconfiguration. The proof indicates that the CICD-Build-Role was associated with a customer-managed policy with escalation-level permissions like `iam:PassRole`, `iam:AttachRolePolicy`, and `iam:PutRolePolicy`, without any permissions boundary or condition block. In the meantime, this would imply that an attacker who has accessed such a role, which can escalate effective privileges, expand access throughout the AWS environment and, eventually, evolve from typical operational privilege accesses to a much wider set of administrative capabilities.

A third major threat is unauthorized access to sensitive cloud data. Production S3 bucket in storage is the principal venue for this data. The successful `GetObject` event against prod-finance-reports demonstrates that in this case, the security threat isn't only a theoretical IAM weakness; it is also that sensitive financial reporting data itself is accessed. In a regulated enterprise situation, this gives rise to important threat exposure for confidentiality, compliance, contractual obligations, and organizational trust. Thus, the threat landscape of this case should be viewed as a mix of valid-account abuse, escalation ability, and high-value data access in production AWS.

6. Threats, Vulnerabilities, and Existing Control Weakness

The appendix (A) proof indicates that the AWS environment contained various pre-existing weak links that increased the odds of, and potential effects of, cloud identity abuse. Identity

sprawl was the most salient issue, demonstrated by the huge number of IAM users, roles, and customer-managed policies inside the account. This complexity of IAM is what makes it a challenge to provide the right IAM governance over access, maintain consistent rights review, and enforce least privilege throughout the environment. Excessive privilege exposure was a second key weakness. As can be seen from Appendix A, multiple identities were severely privileged, including three who have AdministratorAccess. In a production AWS environment, widespread administrative access will dramatically increase blast radius because, compromised by one privileged identity, one might compromise a host of resources, services, and security controls. Poor privileged access controls were also observed in the environment.

There was no MFA enabled for privileged users, and no permission boundaries. Combined, such gaps limited the efficacy of preventive controls, which might otherwise have minimized abusive use of malicious identities or restricted escalation-capable permissions. This rendered the IAM environment more permissive and inefficient in preventing misuse of legitimate cloud identities. Another essential vulnerability was the existence of risky IAM policy permissions. The CICD-Build-Role connected with DevOps-ExtendedAccess policy supports (iam:PassRole, iam:AttachRolePolicy, and iam:PutRolePolicy on Resource: "*", no condition block and no permission boundary to enforce the following roles. These permissions are a notable consideration because, if given to an operation or automation role in a production cloud scenario, they may give rise to privilege escalation or wider role abuse.

Overall, these conditions highlight low least-privilege enforcement. The flaw was not the result of a single policy; on the whole, the architecture of IAM has appeared to have preferred operational ease to narrow access restrictions. This developed a context for an appropriate cloud role to discover, escalate, and access sensitive data with little preventive limitation. From the perspective of monitoring, though, the evidence shows there was some detection, but it was mostly reactive. SIEM resulted in a high-severity alert for IAM enumeration successfully, which is a good control, but that same role was able to see sensitive S3 data shortly thereafter. This means that while suspicious activity was detected, the controls available were not able to stop the transition from discovery activity to successful data access within the defined time frame.

7. Chronological Attacker Narrative

7.1 IAM Enumeration (Discovery)

The first incident of the incident involved the principal arn:aws:iam::123456789012:role/CICD-Build-Role engaging in suspicious IAM discovery activity. Based on the SIEM alert evidence, the first activity was detected at 2026-02-12T02:14:03Z and continued until 2026-02-12T02:18:44Z. [Here, the role was running the APIs ListUsers, GetPolicy, and ListRoles], indicating active enumeration of IAM identities,

roles, and permission structures on AWS for the role, and it started executing them. This behavior is consistent with an actor seeking to understand a cloud account architecture and access privilege pathways vs. simply using ordinary app actions. **Appendix A — Figure 3;** EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CICD-Build-Role.

From an incident reconstruction viewpoint, this activity is the Discovery stage in the attack chain. These APIs are relevant for cloud identity reconnaissance because they help the actor to identify existing IAM users, available roles, and the permissions for those roles/ Policies. But more precisely, this allows an attacker to find out what accounts or identities have privileges over others, which identity or role you can abuse or abuse without, and what policy configurations enable upward motion or access to certain high-value resources. **Appendix A — Figure 3;** EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CICD-Build-Role.

This process is related to TA0007— Discovery and more specifically T1087.004—Account Discovery: Cloud Account, as the actor was counting individual cloud identities and appropriate permission structures. There is also evidence for the view that the role did not only connect one application resource with them but was inspecting IAM in a broader scope, which is almost always the nature of attack preparation inside a cloud infrastructure. **Appendix A — Figure 3;** EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CICD-Build-Role.

7.2 Identification of Escalation Path

After finding out about IAM, the evidence in the appendix suggests that the actor had a high-risk IAM policy named DevOps-ExtendedAccess attached to the CICD-Build-Role, so that he might access it. As shown in **Appendix A – Figure 2;** API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role. , under this customer-managed policy, it allowed the following actions: iam:PassRole, iam:AttachRolePolicy, and iam:PutRolePolicy with authorization scope defined as Resource: "*". The above confirms that no permission boundary was set, and no block condition imposed any restriction on policy use.

This policy is noteworthy for its plausible privilege escalation path. -permission iam:PassRole can allow a role to pass more privileged roles on AWS services or workloads, and in other ways, iam:AttachRolePolicy and iam:PutRolePolicy can allow a role to attach stricter policies or change inline role-permissions directly. When these actions are granted fairly freely, all around all resources and without permission or conditionality they substantially increase the chances for an attacker to gain elevated access to routine operational access. **Appendix A – Figure 2;** API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role.

Instead of the proof of a completed privilege change, this stage consists of identifying an escalation, which is when the best action is made. According to the evidence, the earlier

evidence activity regarding the IAM itself would have allowed them to view roles, and policy structures that were available, and the use of the role in **Appendix A – Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role. supports escalation capability. This stage correlates with T1098 – Account Manipulation and is in accordance with T1548.005 – Abuse Elevation Control Mechanism: Temporary Elevated Cloud Access, as the policy architecture can facilitate cloud-native privilege abuse due to legitimate identity mechanisms.

7.3 Privilege Escalation

It provides evidence that there is an opportunity for privilege escalation, but it doesn't show anything like an executed escalation API event, like AttachRolePolicy, PutRolePolicy, or AssumeRole done after the discovery phase. This is why this assessment is written with deliberation and evidence behind it. On the other hand, it is defensible to assume that the CICD-Build-Role had the right access to privilege escalation capabilities, and that the actor's discovery activity on his IAM was indicative of the detection and preparation to take such an approach. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role. **Appendix A — Figure 3**; EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CICD-Build-Role.

In reality, the escalation path was a dangerous one - because the role had scope to change or broaden permissions in a loose, poorly constrained IAM environment that was deficient in permission boundaries and MFA enforcement against privileged users. This suggests that the agent wielding the role may have been able to bolster effective privileges, expand their reach/area of access, or obtain a larger breadth of AWS resource control. While the appendix artifacts are not available, giving details on an exact stage of escalation, it does confirm the discovery activity and escalation-capable policy permissions, and that access to high value data occurred. **Appendix A — Figure 1**; Principal: AWS IAM environment; Risk: Excessive Privilege & Identity Sprawl. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role.

With MITRE ATT&CK at least, this stage is most appropriately mapped to T1098 — Account Manipulation, which has supporting relevance to T1548.005 — Abuse Elevation Control Mechanism: Temporary Elevated Cloud Access. If the permissions have been used to create or preserve additional identity access, T1098.003 — Account Manipulation: Additional Cloud Credentials may add conceptually to MITRE ATT&CK, a clear CreateAccessKey event which could provide concrete details is not shown in the appendices artifacts; therefore, mapping should be done with caution and to be considered only as a supplementary analytical reference and not a confirmed action in this incident. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role.

7.4 S3 Data Access

At 2026-02-12T02:20:15Z, CloudTrail logged a successful GetObject event against the S3 bucket prod-finance-reports. The event belonged to the same principal,

arn:aws:iam::123456789012:role/CICD-Build-Role, which previously triggered the high-severity IAM enumeration alert. Further evidence from CloudTrail notes that the authorization happened approximately six minutes post the initial discovery alert, establishing a close temporal link between suspicious IAM reconnaissance and subsequent access to sensitive production data. **Appendix A — Figure 4**; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CICD-Build-Role.

This event marks the part of the incident where data is accessed. The GetObject event, in contrast to the earlier phases that concentrated on identity reconnaissance and escalation opportunity, validates that the actor has interacted with a high-value business asset. The target bucket, prod-finance-reports, is particularly striking; the organization indicates S3 to host sensitive information related to financial reporting in a regulated production environment. Accordingly, this action markedly raises the seriousness of the incident by demonstrating that the activity developed beyond exploration and into established access to sensitive cloud-stored data. **Appendix A — Figure 4**; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CICD-Build-Role.

This connects closely to T1530 — Data from Cloud Storage, since the actor took a proper AWS role for fetching an object from S3. It is also consistent with T1078.004 — Valid Accounts: Cloud Accounts, as the behavior was carried out via an approved cloud identity, not through noisy or plainly external exploit attempts. The positive outcome for this event is indicative that access was finally performed, and not just attempted, making the point that there was sensitive business data exposed on the production AWS platform. **Appendix A — Figure 4**; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CICD-Build-Role.

8. MITRE ATT&CK Mapping

The observed activity illustrated in Appendix A was mapped using the MITRE ATT&CK framework to classify the attacker’s behavior according to standardized tactics and techniques. (Mapping below builds on SIEM alert, IAM policy evidence, CloudTrail event data & supporting JSON snippets) The mapping is done only when the techniques are supported by the evidence presented and when the evidence highlights an escalation opportunity rather than what has been previously confirmed as an escalation action.

Observed Activity	MITRE ATT&CK Mapping Details
IAM enumeration by CICD-	API Calls: ListUsers, GetPolicy, ListRoles

Build-Role	Timestamp: First seen 2026-02-12T02:14:03Z Appendix Figure: Figure 3 Tactic: Discovery Technique ID: T1087.004 Account Discovery: Cloud Account Why it fits: These API calls show the actor was enumerating IAM identities, roles, and permission-related structures inside the AWS account.
Discovery of role and permission structures relevant to privileged access paths	API Calls: GetPolicy, ListRoles Timestamp: 2026-02-12T02:14:03Z to 2026-02-12T02:18:44Z Appendix Figure: Figure 3 Tactic: Discovery Technique ID and Name: T1069.003 — Permission Groups Discovery: Cloud Groups Why it fits: The activity indicates inspection of IAM roles and policy structures to understand access groupings and possible privileged paths.
Escalation-capable IAM policy attached to CICD-Build-Role	API Calls / Permissions: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy Timestamp: N/A in static policy artifact Appendix Figure: Figure 2 Tactic: Privilege Escalation / Persistence Technique ID and Name: T1098 — Account Manipulation Why it fits: These permissions could allow modification or expansion of access through legitimate IAM mechanisms.
Cloud-native privilege	API Calls / Permissions: iam:PassRole,

escalation opportunity through broad role permissions	iam:AttachRolePolicy, iam:PutRolePolicy Timestamp: N/A in static policy artifact Appendix Figure: Figure 2 Tactic: Privilege Escalation Technique ID and Name: T1548.005 — Abuse Elevation Control Mechanism: Temporary Elevated Cloud Access Why it fits: The policy design could enable temporary elevated access because it is broad, unrestricted, and lacks condition blocks and permission boundaries.
Use of a valid AWS role throughout the incident	API Calls: ListUsers, GetPolicy, ListRoles, GetObject Timestamp: 2026-02-12T02:14:03Z and 2026-02-12T02:20:15Z Appendix Figures: Figures 3 and 4 Tactic: Initial Access / Persistence Technique ID and Name: T1078.004 — Valid Accounts: Cloud Accounts Why it fits: The activity was performed using the legitimate CICD-Build-Role, which fits valid cloud account usage.
Successful access to sensitive S3 data	API Call: GetObject Timestamp: 2026-02-12T02:20:15Z Appendix Figure: Figure 4 Tactic: Collection Technique ID and Name: T1530 — Data from Cloud Storage Why it fits: CloudTrail confirms retrieval of an object from the prod-finance-reports bucket, which directly matches cloud storage data collection.

Table 1: Mitre Att&ck Mapping Demonstration

The mapping suggests a cloud-identity-centered attack pattern starting from discovery of IAM to identification of an access path capable of escalation and successful access to sensitive S3-hosted financial data. The best documented mappings are T1087.004 — Account Discovery: Cloud Account, T1078.004 — Valid Accounts: Cloud Accounts, and T1530 — Data from Cloud Storage, respectively, while T1098 — Account Manipulation and T1548.005 — Abuse Elevation Control Mechanism: Temporary Elevated Cloud Access are mentioned and escalation-capable IAM conditions shown in appendix.

9. Top Two Risk Assessment

List Risk ratings of this section were computed with the 5×5 likelihood and impact matrix shown in **Appendix B**; likelihood was assessed based on ease of exploitation, exposure of escalation-capable permissions, absence of preventive controls, and observed actor behavior. Impact was assessed based on the sensitivity of affected data, the privilege level of the involved role, the potential blast radius within the AWS environment, and the business consequences associated with a regulated enterprise cloud environment.

9.1 Risk 1: Excessive IAM Privileges Enabling Privilege Escalation and Broad Cloud Compromise

Description: In this assessment, the most significant risk was the presence of excessive IAM permissions, which created a credible privilege escalation opportunity within AWS. The CICD-Build-Role was attached to the DevOps-ExtendedAccess policy that allowed iam:PassRole, iam:AttachRolePolicy, and iam:PutRolePolicy on Resource: "*" without a condition block or permission boundary. Within a production cloud context, these permissions provide an actor using a valid role to manipulate access, extend privileges, and potentially widen control over AWS resources beyond the role's intended operational function.

Supporting Evidence: Appendix A displays several potential conditions that endorse this risk. Figure. 1 reveals identity sprawl, privileged access exposure, no MFA for privileged users, and no permission boundaries throughout IAM. The escalation-capable policy is displayed in Figure 2 for CICD-Build-Role. Figure 3 further verified the same role did questionable IAM discovery with the use of ListUsers, GetPolicy, and ListRoles, therefore aligning with the detection and preparation of misuse of privileged access paths. Between them, such artifacts suggest the risk was not abstract, but it was present in an operational role later in the incident data. **Appendix A -- Figure 1**; Risk: Excessive Privilege & Identity Sprawl. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role. **Appendix A — Figure 3**; EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CICD-Build-Role.

Likelihood: The likelihood of this risk is estimated to be **Likely (4)**. The permissions already existed in the environment, they were attached to an operational role, and there were no strong preventive controls such as MFA enforcement for privileged access or permission boundaries to reduce abuse potential. The observed IAM discovery activity also indicates that the actor was actively exploring roles and permissions, which increases confidence that the escalation-capable design represented a realistic exploitation opportunity rather than a passive configuration issue.

Impact: The effect of this risk is categorized as **Severe (5)**. Abuse of escalation-capable IAM permissions could allow broader compromise of cloud resources, policy manipulation, and expansion of access within the production AWS environment. As IAM is key to supporting build pipelines, services, and administrative operations, abuse of privilege at this layer may impact many of our business systems, further compromising the overarching security posture of the organization.

Business Consequence: This risk, on a business basis, could result in unauthorized administrative control, expansive account compromise, service disruption, regulatory exposure, and also expensive incident response work. With a risk profile in a well-regulated enterprise environment, misuse of privilege over cloud identities will also bring in audit concerns, reduce trust in access governance, and cause long-term security and compliance implications.

Risk Rating / Priority: Using the 5×5 risk matrix in Appendix B, a **Likelihood of 4 (Likely)** and **Impact of 5 (Severe)** produces a score of **20**, which supports a **High / Critical Priority** risk rating. This is assessed as the **highest-priority risk** in the report.

9.2 Risk 2: Unauthorized Access to Sensitive Financial Reporting Data in S3

Description: Unauthorized access to sensitive financial reporting data in Amazon S3 is the second most significant risk. As per CloudTrail, the CIGD-Build-Role executed a GetObject operation against the prod-finance-reports bucket at 2026-02-12T02:20:15Z; hence, the incident progressed beyond suspicious discovery activity and into confirmed access to production business data. In a regulated environment, successful access to sensitive financial reporting data materially increases the seriousness of the incident because it creates immediate confidentiality and compliance concerns. **Appendix A — Figure 4;** EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CIGD-Build-Role.

Supporting Evidence: The organizational context states that the enterprise stores sensitive financial reporting data in S3 and that compromise of privileged roles or unauthorized access to production S3 data could result in regulatory penalties, contractual breaches, financial loss, reputational damage, and operational disruption. Figure 4 provides direct evidence of successful GetObject access to the prod-finance-reports bucket by the same role that triggered the earlier high-severity IAM enumeration alert. The close timing between the IAM discovery activity and the S3 access strengthens the conclusion that the data access was part of the same suspicious activity chain. **Appendix A — Figure 3;** EventTime: 2026-

02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CICD-Build-Role.

Appendix A — Figure 4; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CICD-Build-Role.

Likelihood: The likelihood of this risk is assessed as **Moderate (3)**. The data is retrieved; however, no evidence in the appendix indicates ongoing access, mass collection, or clear exfiltration beyond the successful GetObject incident. But because access happened, this is more than a hypothetical risk. The rating indicates the event has been proved, while the wider extent of the data compromise is not fully visible from the evidence provided.

Impact: The risk is rated as **Severe (5)**. The impacted bucket contains financial reporting data in a production AWS environment, and the entity operates in a regulated sector. Unauthorized access to such data can cause immediate concerns related to confidentiality, reporting integrity, legal obligations, and trust. Even a limited confirmed access event can make a difference when the data in question is operationally and financially sensitive.

Business Consequence: It is the risk that will lead to regulatory penalties, contractual breaches, financial loss, damage to the goodwill of the organization, and the disruption of normal business processes. It may even result in further forensic investigation, breach assessment, reporting obligations, and extra focus on cloud governance controls. Moreover, because the bucket is associated with financial reporting, the business consequence extends beyond technical exposure and involves governance, compliance, and stakeholder confidence.

Risk Rating / Priority: Using the 5×5 risk matrix in Appendix B, we have a Likelihood of **3 (Moderate)** and Impact of **5 (Severe)**, yielding a score of **15**, indicating a High Priority risk rating. This risk is evaluated as the second-highest risk in the report.

10. Root Cause Analysis

This incident was not based on one individual misconfiguration and is instead due to a broader weakness in IAM governance and privilege management across the AWS environment. Appendix A indicates that the organization had a highly convoluted and overly permissive identity structure with 27 IAM users, 41 roles, and 96 customer-managed policies. This level of identity and policy sprawl increased the difficulty of maintaining visibility over access rights and enforcing strong privilege boundaries across operational roles. In practice, it seems that the environment worked in a way that prioritized flexibility and speed rather than a tightly governed identity control.

An important technical root cause was the presence of escalation-capable permissions attached to an operational cloud role. The CICD-Build-Role was connected to the DevOps-ExtendedAccess policy that allowed iam:PassRole, iam:AttachRolePolicy, and iam:PutRolePolicy on Resource: "*", with no condition block and without a permission

boundary. These privileges provided a credible path by which a valid cloud identity could inspect, manipulate, or extend access using legitimate AWS IAM mechanisms. This implies a failure to properly restrict high-risk IAM actions to narrowly controlled administrative contexts.

The second root cause was the failure to enforce least privilege. The IAM environment contained multiple indicators that access control was broader than operationally necessary, including users with AdministratorAccess, missing MFA for privileged users, and the absence of permission boundaries. These conditions suggest that the organization lacked sufficient preventive controls to ensure that roles were scoped only to required business functions. As a result, the CICD-Build-Role appears to have held permissions that were inconsistent with a narrowly limited CI/CD function and therefore posed unnecessary security risk.

Weak privileged access governance also facilitated the incident. High-risk IAM actions were available within an operational role, but critical guardrails, such as MFA enforcement and permission boundaries, were missing. This meant that if a valid cloud role was compromised or misused, the environment offered limited resistance to abuse of powerful permissions. In other words, the control design did not sufficiently separate routine operational capability from high-impact IAM administration.

Another factor was the detection-prevention gap. The SIEM did generate a high-severity alert for IAM enumeration activity, hence suggesting this activity had monitoring controls working. But shortly afterward, the same role managed to access the prod-finance-reports S3 bucket. It suggests that the organization's defensive posture was more effective in finding suspicious behavior than in preventing rapid progression from identity discovery to sensitive data access. In root cause language, the control environment detected the suspicious activity but did not contain or interrupt the incident in time to prevent business-impacting access.

Altogether, the incident was due to identity sprawl, excessive IAM privilege, weak least-privilege enforcement, insufficient preventive guardrails, and limited containment capability after detection. All this combined made for a scenario in which a valid AWS role could be leveraged to enumerate cloud identities, identify escalation opportunities, and successfully access sensitive financial reporting data in S3. That means the root cause of the incident is mainly an IAM governance and cloud access control failure, rather than a purely isolated technical event.

11.Mitigation Recommendations

Mitigations (recommended) are derived directly from the two most critical risks identified in Section 9: (1) excessive IAM privileges enabling privilege escalation and broader cloud

compromise, and (2) unauthorized access to sensitive financial reporting data in S3. These recommendations are meant to lower the risk of future cloud identity abuse, limit the impact of misuse of valid roles, and fortify the defense for sensitive business data. The environment already had identity sprawl, privileged access exposure, no MFA for privileged users, no permission boundaries, and escalation-capable permissions associated with the CICD-Build-Role (Appendix A). Appendix A — Figure 1; Principal: AWS IAM environment; Risk: Excessive Privilege & Identity Sprawl. Appendix A — Figure 2; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role.

11.1 Restrict High-Risk IAM Permissions and Redesign the DevOps-ExtendedAccess Policy

To that end, the most critical mitigation is to remove or severely curtail escalation-capable IAM permissions of operational roles, in particular iam:PassRole, iam:AttachRolePolicy, and iam:PutRolePolicy. In the present context, the DevOps-ExtendedAccess policy had already provided these permissions on Resource: "*", without any condition block or permission boundary. This design needs to be replaced with a model of least-privilege, meaning that those high-risk IAM actions are restricted exclusively to specific administrative roles, allocated resources, and well-documented business use cases. The CICD-Build-Role shall only have the permissions that are absolutely necessary for the CI/CD operations and also that any broader IAM administration capability of the role shall be stripped. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role.

This recommendation targets its main action point of **Risk 1** because it reduces the incidence of escalation-capable permissions being abused to manipulate access or provide higher privileges in the AWS environment. **Appendix C** — AWS IAM Security Best Practices, **Appendix D** — AWS Guidance on iam:PassRole Restrictions, and **Appendix G** — AWS Well-Architected Least Privilege Guidance endorse it.

11.2 Enforce MFA for Privileged Identities and High-Risk Access Paths

The second key mitigation is to enforce MFA for all privileged identities and for any access path that can reach sensitive production resources. MFA was not turned on for privileged users as we see in Appendix A, severely limiting the organization's proactive access controls. MFA should also apply to privileged console access, IAM administration, and other high-value identities where compromise or abuse could affect production systems or regulated data. In practice, this would have made it harder to misuse a legitimate identity and would also provide a second layer of security if credentials were exposed or abused. **Appendix A — Figure 1**; Principal: AWS IAM environment; MFA Enabled for Privileged Users: NO.

This recommendation largely mitigates **Risk 1**, and it also mitigates **Risk 2**, since improved identity assurance can make it more difficult for an attacker to access production data with

privileged or sensitive-access accounts. This is supported by **Appendix C** — AWS IAM Security Best Practices and **Appendix F** — NIST MFA / Digital Identity Guidance.

11.3 Implement Permission Boundaries and Stronger IAM Guardrails

A third suggestion is to mandate permission boundaries and stricter governance for CI/CD, DevOps, and other operational roles. No permission boundaries were set in the appendix, meaning there was no secondary control limiting how powerful a role could become once broad permissions were assigned. Permission boundaries should therefore be introduced so that operational roles aren't granted unrestricted IAM administration capability, even if an overly broad policy is mistakenly attached in the future. Moreover, any role that requires stronger IAM permissions related to higher-impact actions or tasks should be subject to stronger approval, periodic access review, and tighter change control. **Appendix A — Figure 1**; Principal: AWS IAM environment; Permission Boundaries Configured: NO. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role.

This recommendation targets **Risk 1** principally by limiting the blast radius and constraining privilege expansion within the AWS environment. This recommendation is supported by the AWS IAM Security Best Practices in **Appendix C**, and the Well-Architected Least Privilege Guidance in **Appendix G**.

11.4 Tighten Access Control Over Sensitive S3 Data

The fourth recommendation is to harden access control over the prod-finance-reports bucket and any other S3 locations containing regulated or financially sensitive data. CloudTrail confirms that the CICD-Build-Role successfully executed a GetObject operation against this bucket, meaning the incident progressed into confirmed data access. Access to this bucket should therefore be limited to approved principals, approved actions, and clearly defined business need. The organization should review whether any build, automation, or operational roles have unnecessary access to financial reporting data and remove that access immediately where it is not explicitly required. Bucket policies and IAM permissions should be aligned to ensure that non-financial workloads cannot inherit broad access to sensitive reporting data. **Appendix A — Figure 4**; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CICD-Build-Role.

This recommendation primarily addresses **Risk 2** by reducing both the likelihood and impact of unauthorized access to sensitive financial reporting data stored in S3. It is supported by **Appendix E** — Amazon S3 Security Best Practices.

11.5 Improve Detection and Response for IAM-to-S3 Attack Progression

The last recommendation is to have better detecting and responding for chained cloud identity attacks in case of IAM discovery followed by high-risk IAM activity and sensitive S3 access sequences. In this scenario the SIEM detected IAM enumeration behavior but the same role still reached sensitive S3 data shortly afterward. It is recommended to strengthen

the detection logic to better prioritize actions, e.g., ListUsers, GetPolicy, ListRoles and then privilege-related IAM events and GetObject activities that might target sensitive buckets, for example. A faster response playbook would also help this process, to determine the appropriate level of isolating suspicious roles, reviewing active sessions, and to decide if sensitive resource access should be temporarily blocked during investigations. **Appendix A — Figure 3**; EventTime: 2026-02-12T02:14:03Z; API: ListUsers, GetPolicy, ListRoles; Principal: CICD-Build-Role. **Appendix A — Figure 4**; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CICD-Build-Role.

For **Risk 1** and **Risk 2**, this recommendation helps to shorten the time between IAM activity detection and containment and also limits the likelihood that IAM activity that is deemed security risk will extend into business-impacting data access. It is also supported in **Appendix C** — AWS IAM Security Best Practices, **Appendix E** — Amazon S3 Security Best Practices, and **Appendix G** — AWS Well-Architected Least Privilege Guidance.

The priority ranking of Mitigation: The mitigation priorities must then be taken into account. To begin, restructure the DevOps-ExtendedAccess policy and remove escalation-capable IAM permissions from the CICD-Build-Role, as that would most directly target the highest rated risk in the analysis. Second, implement MFA for privileged identities and other high-risk access paths. Third, implement permission boundaries and further IAM governance controls to minimize future privilege drift and blast radius. Fourth, tighten access control on the prod-finance-reports bucket and all other sensitive S3 resources. Fifth, enhance IAM-to-S3 progression patterns for detection and response so that suspicious identity activity can be detected or halted before access to sensitive data. Combined, these mitigations correlate directly to the two identified risks and reduce both the risk and potential impact of recurrence. **Appendix A — Figure 1**: Principal: AWS IAM environment; Risk: Excessive Privilege & Identity Sprawl. **Appendix A — Figure 2**; API: iam:PassRole, iam:AttachRolePolicy, iam:PutRolePolicy; Principal: CICD-Build-Role. **Appendix A — Figure 4**; EventTime: 2026-02-12T02:20:15Z; API: GetObject; Principal: CICD-Build-Role.

12. Residual Risk

Even if the recommended mitigations are fully implemented, some residual risk will remain within the organization's AWS environment. This is because cloud platforms are dynamic, IAM roles and permissions evolve over time, and production systems must continue balancing operational agility with security control. As a result, the organization cannot assume that risk will be completely eliminated simply by correcting the specific weaknesses identified in this incident.

The most significant remaining risk is the continued possibility of valid account misuse within a complex IAM environment. Even after restricting high-risk permissions, enforcing MFA, and applying permission boundaries, the organization will still depend on legitimate

cloud identities and operational roles to support CI/CD pipelines, internal services, and administrative tasks. If those identities are later misconfigured, reused too broadly, or compromised through another pathway, cloud identity abuse may still occur. This means that IAM governance must remain an ongoing control function rather than a one-time remediation exercise.

A potential second risk remnant concern has to do with exposure of sensitive data in S3 and other production tools. Although decreasing S3 permission access will reduce unauthorized access, the presence of sensitive data in the environment will persist and will continue to require continued protection, monitoring and review. For example, continued exposure conditions may mirror those caused by any kind of lateral migration of future access control drift, policy misconfiguration or inappropriate role inheritance, particularly if not caught early enough. Because of this, data security controls should be supplemented by ongoing monitoring and regular access validation.

The residual risk still exists as potential detection and response capability can reduce impact, but it does not provide a guarantee of prevention in every case. The evidence in the appendix indicates the existence of suspicious IAM activity, but that the actor ultimately accessed sensitive S3 data shortly afterward. This shows that even a working monitoring feature cannot stop a fast-moving cloud identity attack. Hence the organization needs to maintain and perfect its alerting, triage and containment system so that incidents of subsequent kind can be stopped more swiftly.

All in all we can describe what the residual risk after mitigation should look like a moderate but manageable danger, if the organization keeps up good governance of IAM, best practices in least privilege enforcement and MFA adoption; it can take care of the access control problems for sensitive data; and monitor ongoing events. Any resulting mitigations would significantly minimize and mitigate the chances/relevance of occurring, but continued security review will be essential since cloud environments, privileged roles and business requirements change over time.

13. Conclusion

Even if the Based on this Threat & Risk Assessment, this incident was attributed to cloud identity weaknesses in a poorly constrained IAM environment. The evidence indicates that the CICD-Build-Role functioned in an AWS account that was impacted by identity sprawl, excessive privilege, missing MFA for privileged users, and the absence of permission boundaries. In that context, the role was tied to a customer-managed policy with escalation-capable permissions, and subsequently executed suspicious IAM discovery activity before accessing sensitive financial reporting data in S3. Collectively, they demonstrate that the incident was not a minor adjustment of configuration but a significant cloud security incident of a technical and business nature. The two main risks in this report were excessive

privileges in IAM that created the privilege escalation opportunity and broader compromise of the AWS account; and unauthorized access to sensitive financial reporting data in S3. It is important to bear in mind that these risks are serious because they affect both the control over cloud identities for an enterprise and its protection of regulated business data. In a production AWS environment, flaws at the IAM layer can easily lead far beyond mere technical exposure: to regulatory, financial, reputational, and operational hazards. The report also identifies poor IAM governance, failure to fully implement least-privilege enforcement, and insufficient preventive guardrails over privileged operational roles as the root cause of the incident. While the IAM enumeration was detected via monitoring controls, the progression from detection to successful S3 access illustrates that detection was not sufficient to prevent business-impacting activity. Thus, an organization must focus on hardening IAM, tighter access controls for critical S3 resources, higher identity assurance with MFA, and more effective containment of cloud identity misuse. On the whole, the incident should be considered a prominent cloud security alert. The recommended controls mentioned in this report would sharply reduce the probability of recurrence, while significant enhancements are required for sustained change: continuous IAM governance, regular access review, and sustained monitoring across the AWS environment that includes these strategies. In a regulated cloud-first enterprise, protecting identity is essential to protecting data, operations, and business trust.

[14. Appendix/References](#)

Appendix A — Canonical Evidence Artifacts

AWS Management Console — IAM Dashboard

Account Summary

IAM Users: 27

IAM Roles: 41

Customer Managed Policies: 96

Users with AdministratorAccess: 3

MFA Enabled for Privileged Users: NO

Permission Boundaries Configured: NO

Risk Identified: Excessive Privilege & Identity Sprawl

Figure 1 — IAM Dashboard Overview

AWS IAM environment summary showing 27 IAM users, 41 IAM roles, 96 customer-managed policies, 3 users with AdministratorAccess, no MFA for privileged users, and no permission boundaries.

AWS Management Console — IAM > Policies > DevOps-ExtendedAccess

Policy Summary

Policy Name: DevOps-ExtendedAccess

Policy Type: Customer Managed

Attached Entities: 2 Roles (including CICD-Build-Role)

Default Version: v3

Permissions Boundary: Not Set

Policy Document (JSON)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "iam:PassRole",
        "iam:AttachRolePolicy",
        "iam:PutRolePolicy"
      ],
      "Resource": "*"
    }
  ]
}

# Condition Block: NONE
# Escalation Risk: Role can grant elevated privileges
```

Figure 2 — IAM Policy Review

Policy review of DevOps-ExtendedAccess, showing escalation-capable permissions including iam:PassRole, iam:AttachRolePolicy, and iam:PutRolePolicy on Resource: "*", with no condition block.

SIEM Alert — IAM Enumeration Detected

Severity: HIGH

Principal: arn:aws:iam::123456789012:role/CICD-Build-Role

First Seen: 2026-02-12T02:14:03Z

Last Seen: 2026-02-12T02:18:44Z

API Calls: ListUsers, GetPolicy, ListRoles

MITRE: TA0007 — Discovery

Technique: T1087.004 — Account Discovery: Cloud Account

Figure 3 — SIEM Alert — IAM Enumeration

High-severity SIEM alert showing suspicious IAM discovery activity by CICD-Build-Role, including ListUsers, GetPolicy, and ListRoles.

CloudTrail Event — S3 Object Access

Event Time: 2026-02-12T02:20:15Z

Event Name: GetObject

Bucket: prod-finance-reports

User ARN: arn:aws:iam::123456789012:role/CICD-Build-Role

Source IP: 52.14.22.199

Result: Success

Occurred 6 minutes after IAM enumeration alert

Figure 4 — CloudTrail — S3 Object Access

CloudTrail event showing successful GetObject access to the prod-finance-reports bucket by CICD-Build-Role at 2026-02-12T02:20:15Z.

IAM Policy Snippet

```
{
  "Effect": "Allow",
  "Action": ["iam:PassRole", "iam:AttachRolePolicy"],
  "Resource": "*"
}
```

CloudTrail Event Snippet

```
{
  "eventTime": "2026-02-12T02:20:15Z",
  "eventName": "GetObject",
  "userIdentity": {"arn": "arn:aws:iam::123456789012:role/CICD-Build-Role"},
  "requestParameters": {"bucketName": "prod-finance-reports"}
}
```

SIEM Alert Log Snippet

```
{
  "severity": "HIGH",
  "principal": "CICD-Build-Role",
  "apiCalls": ["ListUsers", "GetPolicy", "ListRoles"],
  "firstSeen": "2026-02-12T02:14:03Z"
}
```

Figure 5 — Supporting JSON Artifacts

Raw JSON snippets supporting the IAM policy permissions, SIEM alert, and CloudTrail event.

Appendix B — Risk Assessment Matrix

Likelihood and Impact Model							
			Likelihood				
			Rare	Unlikely	Moderate	Likely	Almost Certain
			1	2	3	4	5
Impact	Severe	5	5	10	15	20	25
	Major	4	4	8	12	16	20
	Moderate	3	3	6	9	12	15
	Minor	2	2	4	6	8	10
	Negligible	1	1	2	3	4	5

Figure: Likelihood and Impact Model

A 5×5 risk matrix is used to determine the likelihood, impact, and final priority of the two assessed risks.

(Reference: [ERM | RISK ASSESSMENT PHASE TWO: RISK ANALYSIS - The ALS Group](#))

Appendix C — AWS IAM Security Best Practices

(Reference: <https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>)

Appendix D — AWS Guidance on iam:PassRole Restrictions

(Reference: https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_use_passrole.html)

Appendix E — Amazon S3 Security Best Practices

(Reference: <https://docs.aws.amazon.com/AmazonS3/latest/userguide/security-best-practices.html>)

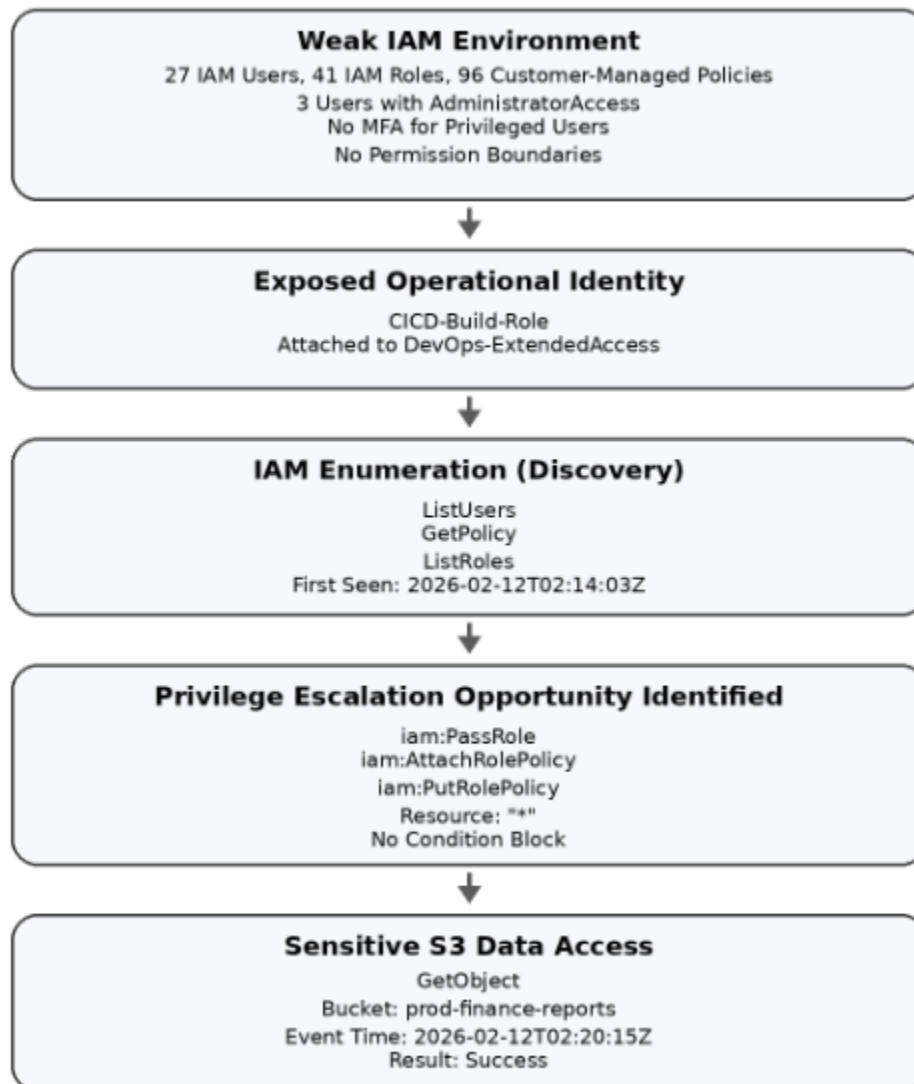
Appendix F — NIST MFA / Digital Identity Guidance

(Reference: <https://pages.nist.gov/800-63-4/sp800-63b.html>)

Appendix G — AWS Well-Architected Least Privilege Guidance

(Reference:
https://docs.aws.amazon.com/wellarchitected/latest/framework/sec_permissions_least_privileges.html)

Appendix H — Attack Path Diagram



Visual summary of the incident progression from weak IAM governance and an exposed operational role to IAM discovery, escalation opportunity, and sensitive S3 data access.